Kuyumcu ERP — Durum ve Yol Haritası

Hazırlayan: **ByGatech A.Ş.** · Tarih: 13 Eylül 2026 · Sürüm: **2.0** (güncellendi)

1. Özet

Tarafınızdan teslim alınan yazılım, çalışan ancak **otomatik testi ve yasal uyum katmanı bulunmayan** bir durumdaydı. Bu aşamada iki iş yapıldı: teslim aldığımız kodda tespit edilen kritik hatalar giderildi ve kuyumculuk mevzuatının yazılıma düşen yükümlülükleri ürüne eklendi.

Bugün itibarıyla **392 otomatik test** çalışıyor ve tamamı başarılı. Yasal zorunluluk planındaki 9 adımın 8'i tamamlandı; kalan tek adım sizden gelecek bir sözleşmeye bağlı.

Bu sürümde ayrıca **uluslararası standartlara dayalı 30 parçalık bir proje belge seti** ve **13 teknik diyagram** hazırlandı. Ölçülmemiş her alan ölçüldü, bulunan dört kusur kapatıldı.

2. Devraldığımız Hâl

Ölçüt	Teslim aldığımızda	Bugün
Program kodu (satır)	6.774	**16.451**
Sistem işlev noktası	78	**100**
Modül	15	**18**
Veri tablosu	16	**21**
Otomatik test	**0**	**392 (tamamı başarılı)**
Veritabanı sürüm yönetimi	**yok**	**9 adım**
Yasal uyum katmanı	**yok**	**var**
Test kapsamı	**ölçülemezdi**	**%72,4**
Proje dokümantasyonu	**yok**	**30 belge, 13 diyagram**

> **Önemli tespit.** Teslim aldığımız kodda kanıtlanmış **6 kritik hata** vardı. En ciddisi, bir müşterinin kaydından başka bir müşterinin kasasına para yazılabilmesiydi — sistem bu işlemi hatasız kabul ediyordu. Bu ve diğer hatalar (çift kayıt, has altın hesabında işaret hatası) giderildi ve tekrarlamasını engelleyen testler yazıldı.

3. Ne Yaptık

3.1 Veri güvenliği ve müşteri ayrımı

- Her kuyumcunun verisi artık sistem düzeyinde ayrılmış durumda. Bir programcı kod yazarken filtreyi unutsa dahi başka bir işletmenin verisi görünmüyor.

- Bu korumanın gerçekten çalıştığı **korumayı bilerek devre dışı bırakarak** sınandı: 13 testin 11'i anında hata verdi, koruma geri konunca tümü düzeldi.
- Müşteri kimlik numaraları veritabanında **şifreli** tutuluyor; diskte açık metin olarak bulunmadığı doğrulandı.
- Kim neyi ne zaman okudu/yazdı kaydı tutuluyor (KVKK gereği).
- Şifre deneme sınırı, güvenli bağlantı zorunluluğu ve erişim kısıtlaması eklendi.
- **Yeni:** Tarayıcı güvenlik başlıkları ve içerik güvenlik politikası eklendi.
- **Yeni:** Kimlik doğrulama (giriş, şifre, oturum yenileme, çalıntı oturum tespiti) baştan sona test edildi.

3.2 MASAK yükümlülükleri

- 185.000 TL ve üzeri işlemlerde **kimlik tespiti olmadan işlem tamamlanamıyor** — uyarı verip geçmiyor, işlemi durduruyor.
- Tutar kademelerine göre işlem amacı ve beyan formu zorunluluğu.
- Şüpheli işlem bildirimi için **10 iş günü sayacı** — hafta sonu ve resmî tatilleri atlayarak hesaplıyor.
- 8 yıllık saklama yükümlülüğü: süre dolunca kayıt silinmiyor, yalnızca kimlik alanları maskeleniyor. Böylece hem denetim izi bozulmuyor hem kişisel veri gereğinden uzun tutulmuyor.
- Eşik tutarları ayar dosyasından okunuyor — mevzuat değişince **program değiştirmeye gerek yok**.

3.3 Vergi ve muhasebe

- **Gider pusulası** (VUK md.234): hurda alımında kimlik zorunlu, T.C. kimlik numarası doğrulaması, tutarın yazıyla yazılması, 7 günlük düzenleme süresi takibi.
- **Stopaj** (GVK md.94): satıcı tipine göre kesinti hesaplanıyor ve kasadan net tutar çıkıyor.
- **Gün sonu POS – fatura mutabakatı**: tahsilat ile kesilen fatura karşılaştırılıyor, fark ve faturasız işlemler listeleniyor.

3.4 Bu sürümde ölçülen ve düzeltilenler

Daha önce "ölçülmedi" diye bıraktığımız her alan ölçüldü:

Ölçüm	Sonuç
Test kapsamı	**%72,4** (çekirdek hesap katmanı %100)
Kod karmaşıklığı	Ortalama **3,0** — 409 fonksiyondan yalnız 8'i eşiğin üstünde
Programın açılış boyutu	**2,42 MB** (önceki raporda 7,53 MB yazmıştık — o ölçüm yanlış yöntemle yapılmıştı, gerçek rakam çok daha iyi)
Yedekten geri yükleme	**22 tablonun 22'si** birebir doğrulandı
Bağımlılık güvenliği	128 bileşen — **0 güvenlik açığı**
Lisans uygunluğu	128 bileşen — **0 kısıtlayıcı lisans**

Bu ölçümler sırasında **dört kusur bulundu ve dördü de kapatıldı**:

Kusur	Etkisi
Kullanıcı IP'si yanlış okunuyordu	Sunucu önündeki yönlendirici nedeniyle tüm kullanıcılar aynı kişi gibi görünüyordu. Sonuç: bir kuyumcu kayıt olunca diğerleri saatlerce kayıt olamıyordu; erişim kayıtlarındaki IP bilgisi anlamsızdı.
MASAK kaydında doğrulama eksiği	Bir işletme, başka bir işletmenin kimlik tespiti kaydını kendi bildirimine bağlayabiliyordu. Bu kayıtlar sonradan değiştirilemediği için düzeltilemezdi.
Giriş sistemi test edilmemişti	Güvenliğin en kritik parçasının test kapsamı %6,7 idi. Şimdi %98.
Bir bileşende güvenlik açığı	Test aracının getirdiği bir bileşende orta seviye açık vardı. Aynı gün bulundu, aynı gün kapatıldı.

> **Bir bulguyu size ayrıca bildirmek isteriz.** Veri tutarlılığı taraması, geliştirme veritabanında **2 satır** bulunan bir kayıt buldu: bir işletmenin kaydı başka bir işletmenin kaydına bağlanmış durumda. İnceledik: bunlar **bizim kendi güvenlik testimizin kalıntısı** — 9 Eylül'de açığı kanıtlamak için oluşturduğumuz "Kurban Kasa" ve "Kurban Müşteri" kayıtları. Aynı tarama, tüm testler çalıştıktan sonra test veritabanında **tertemiz** sonuç veriyor; yani bugünkü yazılımda böyle bir açık yok. Kayıtları **silmedik** — güvenlik bulguları sessizce temizlenmez, raporlanır.

> **Test hakkında dürüst bir not.** Çalışma sırasında **4 gerçek hata** yakalandı ve dördü de yüzlerce başarılı otomatik testten geçmişti. Ancak gerçek veriyle canlı sunucuda çalışırken ortaya çıktılar — örneğin kasa defterinin yön bilgisini kaybetmesi ve stopajın kasadan düşülmemesi. Bu nedenle her adımı canlı ortamda gerçek veriyle ayrıca sınıyoruz. "Testler geçti" tek başına bizim için yeterli kanıt değil.

4. Proje Dokümantasyonu

Projenin uluslararası standartlara dayalı tam belge seti hazırlandı — **30 belge, 13 diyagram**. Herhangi bir firma teknik inceleme yaptığında görmek isteyeceği her başlık mevcut.

Belge grubu	Dayandığı standart	İçerik
Gereksinimler	ISO/IEC/IEEE 29148:2018	Yazılım ve paydaş gereksinimleri, mevzuat izlenebilirliği
Mimari	ISO/IEC/IEEE 42010:2022 · arc42 · C4	Mimari tanımı + **12 karar kaydı** (her kararın gerekçesi ve bedeli)
Kalite	ISO/IEC 25010:**2023**	9 kalite başlığı, 54 ölçülebilir hedef
Test	ISO/IEC/IEEE 29119-3:2021	Test politikası, planı ve tamamlama raporu
Güvenlik	OWASP ASVS 5.0.0 · ISO/IEC 27002:2022	17 başlıkta uygunluk matrisi + tehdit modeli
Süreç	ISO/IEC/IEEE 12207:2017	Yaşam döngüsü + **işletme kılavuzu (runbook)**
Proje yönetimi	PMBOK 8. baskı	Proje planı ve risk kaydı
Değerlendirme	—	Teknik öz-değerlendirme + teknik borç envanteri

Diyagramlar: veri modeli (genel + 4 konu alanı), sistem mimarisi (3 seviye), kullanım senaryoları, işlem akışı ve hurda alımı akışı.

> **İki nokta önemli.** Birincisi: veri modeli diyagramları **elle çizilmedi**, veritabanından otomatik üretiliyor — böylece şema değiştiğinde diyagram yalana dönüşmez. İkincisi: belge setinde **artık geçerli olmayan standartlar bilinçli olarak kullanılmadı**. İnternetteki hazır şablonların çoğu hâlâ geri çekilmiş standartlara dayanıyor; bunu bilen bir inceleyici için bu, güven artıran değil azaltan bir ayrıntıdır.

5. Sırada Ne Var

Pazar araştırması ve iç değerlendirme sonrası belirlenen sıra:

#	İş	Neden
0 ✓	Test altyapısı ve denetim kaydının korunması	**TAMAMLANDI.** Ekran ve sunucu test altyapısı kuruldu; denetim kaydı artık değiştirilemiyor ve yalnız işletme sahibi tarafından görüntülenebiliyor.
1	**Uyum ekranlarının yapılması**	MASAK ve gider pusulası işlevleri çalışıyor, ancak **ekranları henüz yok**. Kullanıcı bugün gider pusulasını yazdıramıyor, şüpheli işlemi ekrandan bildiremiyor.
2	30.000 TL nakit tevsik kontrolü	Aynı gün aynı kişiye yapılan ödemelerin toplamı bu sınırı aşarsa belgelendirme zorunlu. Cezası alıcı ve satıcıya birden kesiliyor.
3	Sentetik taş etiketleme	**24.06.2026 tarihli Resmî Gazete** ile zorunlu oldu: laboratuvar üretimi taşlar etikette, sertifikada ve faturada belirtilmeli, doğal taşlardan ayrı kategoride satılmalı.
4	Veri dışa aktarımı	Sektörde en sık dile getirilen şikâyet, verinin programın içinde kilitli kalması. Verilerinizi istediğiniz an dışarı alabilmeniz sağlanacak.
5	Barkod / etiket basımı	Rakip ürünlerde standart, bizde yok.

6. Neleri Yapamıyoruz — ve Neden

Aşağıdaki maddeler **yazılım eksikliğinden değil**, dış bağımlılıklardan kaynaklanıyor. Tahmine dayalı çözüm üretmeyi tercih etmiyoruz.

Yapılamayan	Sebep	Çözümü
e-Fatura / e-Arşiv	Özel entegratör firmayla sözleşme gerekiyor. Sözleşme olmadan entegratörün test ortamına gerçek fatura gönderilemez; taklit (sahte) bir bağlantı yazıp "yapıldı" demeyiz.	**Entegratör sözleşmesi**
MASAK'a gerçek bildirim gönderimi	MASAK'ın yazılımlar için bir bağlantı arayüzü (API) ve test sunucusu **bulunmuyor**. Bildirim yalnızca MASAK Online sistemine XML dosyası yüklenerek yapılıyor ve bu dosyanın şema tanımı kamuya açık değil. Sistem, bildirimi hazırlıyor ve süresini takip ediyor; gönderim adımı elle yapılıyor.	**MASAK'tan şema; işletme kaydı**
Stopaj oranlarının vergi borcuna işlenmesi	Oran doğrudan para hareketini etkiliyor. Mali müşavir teyidi olmadan rakam varsayamayız.	**Mali müşavir teyidi**
Fatura / e-fatura haddi	Araştırmada dört farklı ve birbiriyle çelişen rakama ulaşıldı. Hangisinin geçerli olduğu teyit edilmeden kodlanmadı; eşik ayar dosyasından okunacak şekilde hazırlandı.	**Mali müşavir teyidi**
KVKK aydınlatma metni	Hukuki metin. Sistem tarafı hazır, metnin kendisi hukuk danışmanınızdan gelmeli.	**Hukuk danışmanı**
KMTS biçim kontrolü	Kayıt alanı eklendi, ancak biçim şeması yayımlanmadığı için doğrulama yazılmadı. Not: Yaptığımız incelemede KMTS'nin perakende kuyumcuya doğrudan yükümlülük getirmediği, kapsamın rafinerilere yönelik olduğu görüldü.	**Şema yayını**

Kapsam dışı bırakılanlar

Aşağıdakiler yasal zorunluluk olmadığı için bu aşamada bilinçli olarak yapılmadı: RFID, toptan satış modülü, imalat/atölye, tamirat takibi, personel ve prim yönetimi, masraf yönetimi, sertifika/katalog, mobil uygulama, e-ticaret entegrasyonu. Bunlar rakip ürünlerde bulunuyor ve ilerleyen aşamada değerlendirilebilir.

7. Sizden Beklediklerimiz

#	Konu	Neyi açar
1	e-Fatura özel entegratör sözleşmesi	e-Fatura / e-Arşiv adımının tamamı
2	Mali müşavir teyidi: fatura haddi ve hurda stopaj oranı	Vergi hesaplarının kesinleşmesi
3	Pilot işletme erişimi	Gerçek veriyle kabul testleri
4	Pilot işletmenin MASAK Online kaydı	Gerçek bildirim gönderimi
5	KVKK aydınlatma metni (hukuk danışmanı)	Yasal metnin sisteme girilmesi
6	**Şifre ve anahtarların yenilenmesi**	Teslim aldığımız kodda veritabanı şifresi ve güvenlik anahtarları sürüm geçmişine kaydedilmiş durumda. Dosyayı düzeltmek yetmiyor; geçmiş kayıt bu bilgileri saklamaya devam ediyor. Bu, geçmişi yeniden yazan bir işlem olduğu için sizin kararınıza bırakıldı.
7	Yazılımın mülkiyet/devir belgesi	Kod sahipliğini gösteren bir belge bulunmuyor. Bu, her ciddi görüşmede sorulan ilk başlıklardandır.

8. Değerlendirme

Uyum ve belgelendirme tarafı tamamlandı; ürün tarafı devam ediyor. Teslim aldığımız yazılımda hiç otomatik test yoktu ve kanıtlanmış 6 kritik hata bulunuyordu. Bugün **392 test**, otomatik kod denetimi, iki katmanlı veri güvenliği ve standartlara dayalı **30 parçalık belge seti** mevcut — güvenliğin çalıştığı ayrıca kanıtlandı.

Buna karşılık ürün, rakiplerle tam kıyaslanabilir olgunlukta değil. Eksik olan yasal katman değil, ticari modüller (barkod, toptan, imalat, mobil). Bunlar kapsam dışı bırakıldığı için eksik; yapılamadığı için değil.

Bir sonraki adım, çalışan uyum işlevlerinin **kullanıcı ekranlarına taşınmasıdır**. Bu tamamlandığında ürün, tek dükkân ve 2–3 şubeli perakende kuyumcu için sunulabilir duruma gelir.

Bu rapordaki tüm sayısal veriler proje kodu üzerinde ölçülerek elde edilmiştir; tahmine dayalı rakam içermez.